

Assignment -3

1: Deploy SonarQube dashboard & Access the Dashboard Part

```
(root@kali)-[~]
└─$ docker run -d --name sonar --restart unless-stopped -e SONAR_ES_BOOTSTRAP_CHECKS_DISABLE=true -p 9000:9000 sonarqube:community
c5f2bd7654b5e6e24bf7c4d4af7590789e43d42636fdb5ea2913aa2f1d35dd00

(root@kali)-[~]
└─$ docker ps -all
```

CONTAINER ID	IMAGE	COMMAND	CREATED	STATUS	PORTS	NAMES
c5f2bd7654b5	sonarqube:community	"/opt/sonarqube/dock..."	5 seconds ago	Up 5 seconds	0.0.0.0:9000→9000/tcp, [::]:9000→9000/tcp	sonar

Update your password

 This account should not use the default password.

Enter a new password

Old Password *

.....

Password *

.....

Confirm Password *

.....

Update

2: Prepare the Vulnerable Repository

```
Session Actions Edit View Help

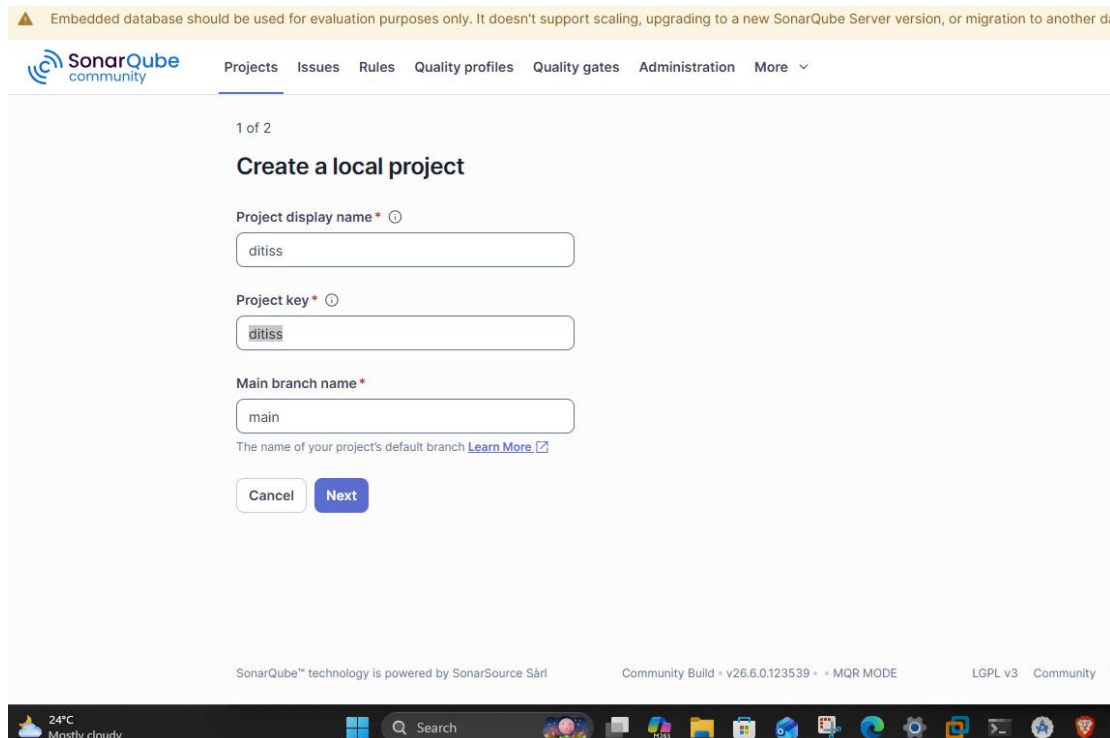
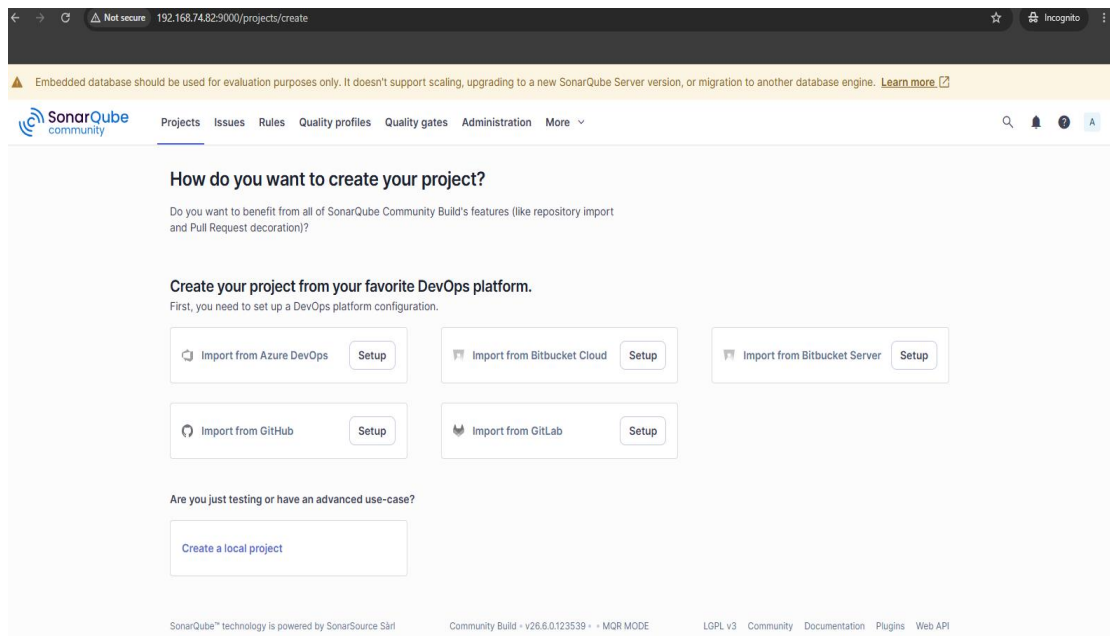
(root@kali)-[~]
└─$ git clone https://github.com/vulnbank/vulnbank.git
Cloning into 'vulnbank'...
remote: Enumerating objects: 921, done.
remote: Total 921 (delta 0), reused 0 (delta 0), pack-reused 921 (from 1)
Receiving objects: 100% (921/921), 17.79 MiB | 18.18 MiB/s, done.
Resolving deltas: 100% (134/134), done.

(root@kali)-[~]
└─$
```

```
(root@kali)-[~]
# cd vulnbank
Issues Pull requests Actions Projects Security and quality

(root@kali)-[~/vulnbank]
# ls
Dockerfile LICENSE nginx.config README.md sources start.sh VulnBank_Guide.pdf
```

3: Create a SonarQube Project with Token



2 of 2

Set up new code for project

The new code definition sets the criteria for what's considered new code, allowing you to focus on the most recent changes in your project.

This setting allows project administrators to customize the new code definition for their project. [Learn more in documentation](#)

Follows the instance's default

Current default: Previous version

Is custom

Choose whether it should be the **previous version**, a **number of days** or a **reference branch**

☐ Previous version

Any code that has changed since the previous version is considered new code. Recommended for **projects following regular versions or releases**.

☒ Number of days

Any code that has changed in the last x days is considered new code. If no action is taken on a new issue after x days, this issue will become part of the overall code. Recommended for **projects following continuous delivery**.

Define the number of days *

30

☐ Reference branch

Choose a reference branch as the baseline for the new code. Recommended for **projects using feature branches**.

Back

Create project

dtiss / Analysis Method

Analysis Method

Use this page to manage and set-up the way your analyses are performed.

How do you want to analyze your repository?

With Jenkins

With GitHub Actions

With Bitbucket Pipelines

With GitLab CI

With Azure Pipelines

Other CI

Locally

Use this for testing or advanced use-case. Other modes are recommended to help you set up your CI environment.

SonarQube Community Build, now it's up to you to launch analyses!

1 Provide a token

Generate a project token

Use existing token

Token name *

secret

Expires in

30 days

Generate

Please note that this token will only allow you to analyze the current project. If you want to use the same token to analyze multiple projects, you need to generate a global token in your [user account](#). See the [documentation](#) for more information.

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your [user account](#).

2 Run analysis on your project

Analyze your project

We initialized your project on SonarQube Community Build, now it's up to you to launch analyses!

1 Provide a token

secret: `sqp_ec2b3589f4fcafd20ac57d1e998305023c095497`

The token is used to identify you when an analysis is performed. If it has been compromised, you can revoke it at any point in time in your [user account](#).

Continue

2 Run analysis on your project

Analyze your project

We initialized your project on SonarQube Community Build, now it's up to you to launch analyses!

2 Run analysis on your project

What option best describes your project?

☐ Maven ☐ Gradle ☐ JS/TS & Web ☐ .NET ☒ Python ☐ Other (for Go, PHP, ...)

Install the Scanner for Python projects

```
pip install pysonar
```

Copy

Please visit the official documentation of the Scanner for Python projects [for more details](#).

Execute the Scanner

Running a SonarQube analysis with the Scanner for Python projects is straightforward. You just need to run the following command in your project's folder.

```
pysonar \
--sonar-host-url=http://192.168.74.82:9000 \
--sonar-token=sqp_ec2b3589f4fcafd20ac57d1e998305023c095497 \
--sonar-project-key=ditiss
```

Copy

Please visit the official documentation of the Scanner for Python projects [for more details](#).



4: Set Up and Run the SonarScanner

Run the Scan

```
(root@kali)~[/vulnbank]
# pysonar \
--sonar-host-url=http://192.168.74.82:9000 \
--sonar-token=sqp_ec2b3589f4fcafd20ac57d1e998305023c095497 \
--sonar-project-key=ditiss
INFO: Starting the analysis...
INFO: Starting SonarScanner Engine ...
INFO: Java 21.0.9 Eclipse Adoptium (64-bit)
INFO: Load global settings
INFO: Load global settings (done) | time=88ms
INFO: Server id: 147B411E-AZ8T65CTgI0autgR7tDX
INFO: Loading required plugins
INFO: Load plugins index
INFO: Load plugins index (done) | time=33ms
INFO: Load/download plugins
INFO: Load/download plugins (done) | time=88ms
INFO: Process project properties
INFO: Process project properties (done) | time=12ms
INFO: Project key: ditiss
INFO: Base dir: /root/vulnbank
INFO: Working dir: /root/vulnbank/.sonar
INFO: Load project settings for component key: 'ditiss'
INFO: Load project settings for component key: 'ditiss' (done) | time=37ms
INFO: Load quality profiles
INFO: Load quality profiles (done) | time=132ms
INFO: Load active rules
INFO: Load active rules (done) | time=559ms
INFO: Load analysis cache
INFO: Load analysis cache (404) | time=13ms
INFO: Preprocessing files ...
```

5: Review Scan Results

31155 / Overview

Overview

21k Lines of Code • Version not provided • Last analysis 1 minute ago

